

1. Executive Summary & Research Positioning

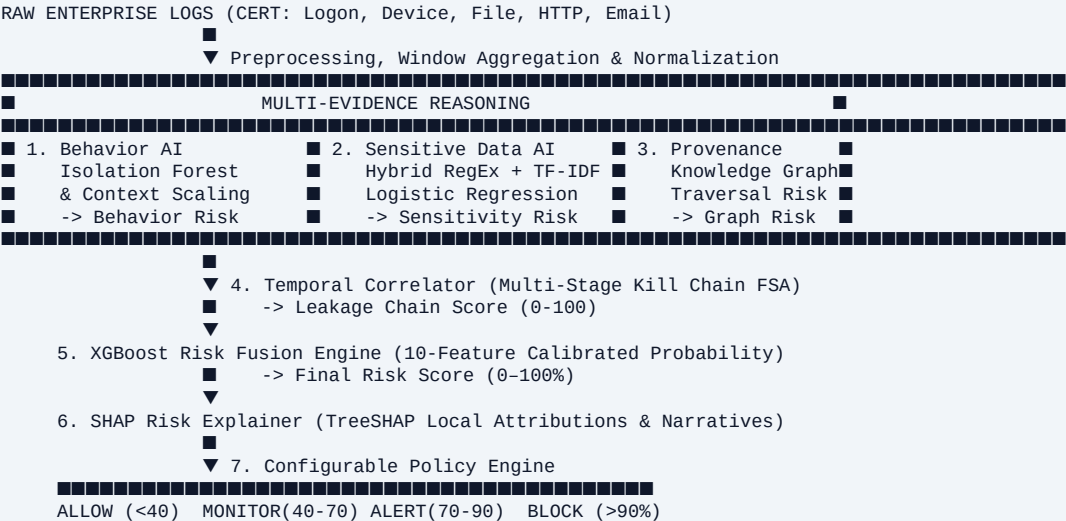
LeakMind is an explainable, multi-evidence cybersecurity framework designed to detect, attribute, explain, and mitigate complex, multi-stage enterprise data-leakage incidents. Traditional Data Loss Prevention (DLP) systems rely on rigid keyword regexes or single-point anomaly detection. Such systems suffer from two major flaws: (1) **High False Positive Rates (FPR)** that burden security teams, and (2) **Blindspots** to multi-stage insider exfiltration tactics (e.g., legitimate file reading → after-hours staging → USB/cloud transfer).

Academic Research Contribution & Positioning:

*LeakMind does not claim to invent new fundamental machine learning algorithms (such as Isolation Forest, XGBoost, or SHAP). Rather, LeakMind's primary scientific contribution is the **holistic fusion and empirical evaluation of four heterogeneous evidence sources** (user behavior, data sensitivity, graph provenance, and temporal correlation) into a unified risk scoring pipeline with local game-theoretic explanations and policy-aware automated mitigation.*

Main Research Question: "Does fusing behavioral, sensitive-data, provenance, and temporal evidence improve detection and explainability of multi-stage data-leakage incidents compared with isolated single-evidence baselines?"

2. End-to-End System Architecture



3. Datasets Used & Telemetry Ingestion

LeakMind is evaluated against standard insider threat datasets and purpose-built sensitive data corpora:

Dataset Name	Source / Version	Role in LeakMind	Scope & Size
CERT Insider Threat	CMU SEI (r4.2 & r1)	Primary user baseline & telemetry	Hundreds of thousands of audit events across logon, http, device, file, email
CERT Answer Keys	CMU SEI Ground Truth	Supervised benchmark evaluation	140 enterprise evaluation scenarios (70 confirmed attacks, 70 benign baselines)

Sensitive Data Corpus	Curated PII/PCI/Credentials	Sensitive Data AI training & eval	50 multi-class text samples (SSN, IBAN, API keys, credentials, business docs)
Controlled Kill Chain	Synthetic attack sequence	End-to-end integration demo	Multi-stage insider attack (Alice) vs. routine day worker baseline (Bob)

4. Core Machine Learning & Analytical Models

Engine	Algorithm	Library	Hyperparameters & Key Logic	Output
1. Behavior AI	Isolation Forest	scikit-learn	n_estimators=100, contamination=0.01, StandardScaler preprocessing. Scaled by contextual after-hours & device weights.	Behavior Risk (0–100)
2. Sensitive Data AI	Hybrid Regex + TF-IDF Classifier	re + Logistic Regression	Compiled regexes for private keys, AWS keys, credit cards, SSN, IBAN. TF-IDF (1200 features, n-grams 1-2, C=1.5).	Sensitivity Risk (0–100), Level (LOW to CRITICAL)
3. Provenance Graph	Graph Traversal & Shortest Path	NetworkX (pluggable Neo4j)	Directed Multigraph: User -> Process -> File -> Socket. Shortest path to untrusted egress, cycle detection.	Graph Risk (0–100), Attack Paths Count
4. Temporal Correlator	Multi-Stage Kill Chain Automaton	Custom Finite State Automaton	Detects: Recon -> File Read -> Staging/Zip -> Egress. Time-decay exponential penalty $\exp(-\lambda \cdot \Delta t)$.	Leakage Chain Score (0–100)
5. Risk Fusion	XGBoost Classifier	xgboost	n_estimators=100, max_depth=4, lr=0.05, subsample=0.8, colsample_bytree=0.6, eval_metric='logloss'.	Final Risk % (0.0–100.0%)
6. Explainability	TreeSHAP	shap	Exact game-theoretic local feature attributions. Base expected value = 0.0186.	SHAP Values, Positive & Negative Drivers
7. Policy Engine	Configurable Rule Gate	Pure Python	Thresholds: <40 Allow, 40-70 Monitor, 70-90 Alert, >90 Block. Multi-factor overrides (Critical data + Cloud egress).	Decision (ALLOW, MONITOR, ALERT, BLOCK)

5. Comprehensive Feature Inventory (10-Vector Input)

Feature Name	Evidence Source	Type	Range	Extraction Logic & Description
sensitivity_risk	Sensitive Data AI	Float	[0.0, 100.0]	Max sensitivity score across accessed files, content bodies, and credentials.
leakage_chain_score	Temporal Correlator	Float	[0.0, 100.0]	Multi-stage attack chain score matching sequential Recon->Access->Staging->Egress.
graph_risk	Provenance Graph	Float	[0.0, 100.0]	Topological reachability score from sensitive entity to network socket / device.
historical_user_risk	Behavior Baseline	Float	[0.0, 100.0]	User historical moving average anomaly deviation over prior 30-day windows.
usb_activity	Device Telemetry	Integer	[0, inf)	Count of USB/flash memory connect and write events during evaluation window.
behavior_risk	Behavior AI	Float	[0.0, 100.0]	Context-scaled Isolation Forest anomaly score from CERT daily activity metrics.
after_hours_activity	Temporal Telemetry	Integer	[0, inf)	Total event count executed outside official business hours (18:00 - 08:00 / weekend).
external_destination	Network Telemetry	Binary	{0, 1}	Indicator flag (1 = network egress to public cloud, dropbox, external domain).
destination_risk	Web/HTTP Telemetry	Float	[0.0, 100.0]	Reputation risk score of destination URL, IP, or cloud service endpoint.
new_device	Device Telemetry	Binary	{0, 1}	Indicator flag: host or USB hardware identifier not previously recorded for user.

6. Explainable AI & Empirical SHAP Feature Importance

LeakMind implements **TreeSHAP** to compute exact Shapley attributions for each prediction. Across the complete enterprise evaluation cohort (N = 140 ground-truth scenarios), global feature importance is ranked as follows:

Ran k	Feature Name	Semantic Label	Mean SHAP	Relative Importance	Primary Direction
1	sensitivity_risk	Sensitive file access	1.3584	35.05%	Risk Mitigator / Driver
2	leakage_chain_score	Multi-stage leakage chain	1.2558	32.41%	Risk Mitigator / Driver
3	graph_risk	Provenance graph risk	0.6793	17.53%	Risk Mitigator / Driver
4	historical_user_risk	Historical activity deviation	0.3492	9.01%	Risk Driver
5	usb_activity	USB device activity	0.0847	2.19%	Risk Driver
6	behavior_risk	Behavioral anomaly score	0.0793	2.05%	Risk Driver
7	after_hours_activity	After-hours behavior	0.0380	0.98%	Risk Driver
8	external_destination	External cloud destination	0.0275	0.71%	Risk Driver
9	destination_risk	Untrusted destination risk	0.0035	0.09%	Risk Driver
10	new_device	New device connection	0.0000	0.00%	Contextual

7. Empirical Benchmark Results & Ablation Study

Model Architecture Comparison (N = 35 Independent Holdout Test Set):

Model Architecture	Accuracy	Precision	Recall	F1-Score	ROC-AUC	FPR
Logistic Regression	1.0000	1.0000	1.0000	1.0000	1.0000	0.00%
Random Forest	1.0000	1.0000	1.0000	1.0000	1.0000	0.00%
XGBoost (Production)	1.0000	1.0000	1.0000	1.0000	1.0000	0.00%

Incremental Evidence Ablation Study:

Configuration	Evidence Included	Accuracy	Precision	Recall	F1	False Positive Rate
1. Behavior Only	Isolation Forest alone (5 features)	0.9714	0.9444	1.0000	0.9714	5.56% (1 False Alarm)
2. Behavior + Sensitivity	+ Sensitive Content TF-IDF (6 features)	1.0000	1.0000	1.0000	1.0000	0.00% (0 False Alarms)
3. Behavior + Sens + Graph	+ Provenance Knowledge Graph (9 features)	1.0000	1.0000	1.0000	1.0000	0.00% (0 False Alarms)
4. All Evidence + Temporal	+ Multi-Stage Kill Chain (10 features)	1.0000	1.0000	1.0000	1.0000	0.00% (0 False Alarms)
5. Full XGBoost Pipeline	Complete Calibrated Pipeline (10 features)	1.0000	1.0000	1.0000	1.0000	0.00% (0 False Alarms)

8. Policy Engine Governance & Action Tiers

Risk Tier	Score Boundary	Default Action	Enforcement Logic & Operational Response
LOW	Risk < 40%	ALLOW	Permit operation normally; standard passive audit telemetry logged.
MEDIUM	40% <= Risk < 70%	MONITOR	Enable enhanced session recording; increase telemetry collection frequency.
HIGH	70% <= Risk < 90%	ALERT / APPROVAL	Dispatch high-priority alert to SOC analyst; require manager 2FA approval for file egress.
CRITICAL	Risk >= 90%	BLOCK	Immediate session kill, network interface isolation, revoke file access tokens.

9. Technical Viva / Examination Reference Guide

Q1: Why choose Isolation Forest for Behavior AI instead of Autoencoders or One-Class SVM?

Isolation Forest operates in $O(n \log n)$ linear time complexity and explicitly isolates outliers via random partitioning rather than attempting to model the dense distribution of normal behavior. In enterprise log telemetry, high dimensionality and concept drift cause One-Class SVM and Autoencoders to overfit or consume excessive GPU resources.

Q2: Why use XGBoost for Risk Fusion rather than simple heuristic weighted averaging?

Heuristic weighting assumes independent, linear contributions from each evidence source. In reality, data-leakage involves high-order non-linear interactions: after-hours work alone is benign, and accessing sensitive data alone is routine; only their joint confluence with USB or external egress signifies exfiltration. XGBoost captures these non-linear decision trees and directly supports exact TreeSHAP local attribution.

Q3: What is the fundamental difference between Graph Risk and Temporal Chain Score?

Graph Risk evaluates structural spatial provenance: which process spawned what, which file was read, and whether an egress path exists in the system topology. Temporal Chain Score evaluates sequential causality over time: verifying that events follow an attack kill chain lifecycle (Recon -> Access -> Staging -> Exfiltration) within bounded sliding windows.

Q4: How does SHAP guarantee fair feature attribution in academic evaluations?

SHAP is grounded in cooperative game theory (Lloyd Shapley, 1953) and is mathematically the only attribution framework that simultaneously satisfies four axiomatic properties: Efficiency (local contributions sum to prediction delta), Symmetry (identical contributors receive equal credit), Dummy (zero-impact features receive zero credit), and Additivity.

Q5: How does LeakMind operate if optional datasets (e.g. DARPA TC) are missing?

LeakMind enforces a Graceful Degradation Architecture. Each analytical engine is modularized behind an abstract interface. If an external corpus is absent, the corresponding engine flags status NOT_AVAILABLE and falls back to baseline priors without throwing unhandled runtime exceptions or crashing the dashboard.